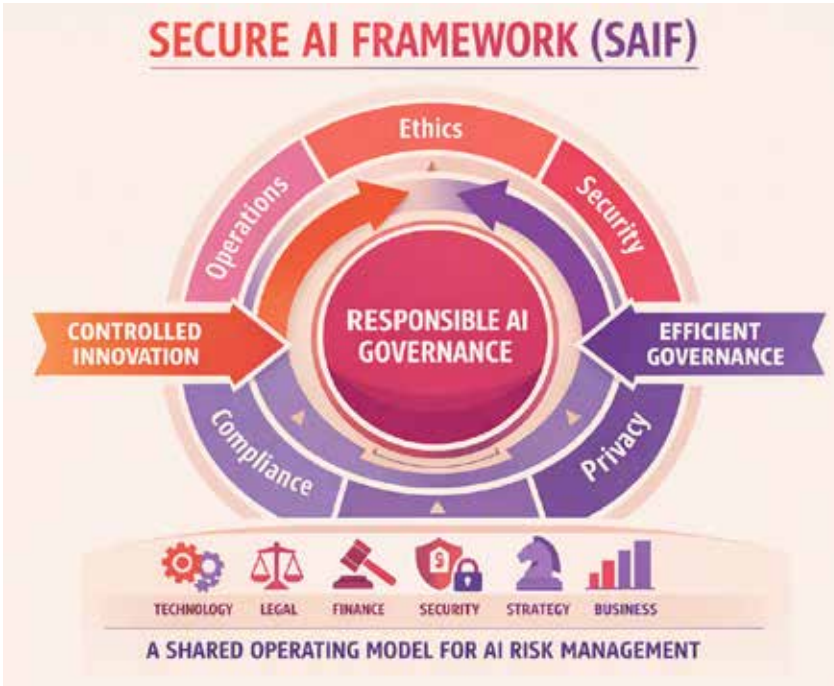



Figure 1: Prototype of the Secure AI Framework

infrastructure, models, applications, assurance practices, and executive oversight. In simple terms, SAIF helps an enterprise ask the right questions before, during, and after an AI solution is deployed: What data is being used? Who can access the model? How are prompts and outputs monitored? What happens when the system behaves unexpectedly? Who is accountable for approving, funding, securing, and operating the AI capability?

## Why SAIF matters for AI governance

AI governance is the discipline of directing, controlling, and continuously improving the way AI is developed and used. It connects business objectives with ethical expectations, regulatory obligations, cybersecurity controls, operational resilience, and measurable accountability. Without governance, AI initiatives often grow in fragmented ways. One team may build a chatbot using customer data, another may create a predictive model for operations, and a third may experiment with generative AI for software delivery. Each initiative may be useful, but the organisation may lack a common policy for data handling, access control, model validation, human review, auditability, and incident response.

SAIF strengthens AI governance by converting security and risk thinking into repeatable processes. It encourages organisations to define guardrails before AI moves into production, align AI risk with enterprise risk management, and create ownership across technology, security, legal, finance, strategy, and business teams. It also makes governance more practical. Rather than treating AI ethics, security, privacy, compliance, and operations as separate conversations, SAIF brings them into a shared operating model. This helps leaders avoid two common extremes: uncontrolled innovation on one side and excessive bureaucracy on the other.

## How SAIF helps an organisation build governance and process

SAIF helps organisations move from informal AI experimentation to disciplined AI delivery. First, it creates a common vocabulary for AI risk. Teams can discuss prompt injection, data leakage, model theft, adversarial behaviour, hallucination risk, privacy exposure, and agentic misuse without treating them as isolated technical concerns. Second, it embeds security into each stage of the AI lifecycle, from use-case intake and data selection to model testing, deployment, monitoring, and retirement. Third, it clarifies decision rights. Leaders can decide which AI systems require executive approval, which controls are mandatory, and which risks must be accepted formally.

A SAIF-based process typically begins with an AI use-case assessment. The business sponsor explains the intended value, the AI head assesses feasibility, the chief security officer evaluates threat exposure, the CIO confirms platform readiness, and the legal or compliance team reviews regulatory implications. After that, the organisation defines control requirements such as identity and access management, data classification, model evaluation, human oversight, secure logging, output filtering, red-team testing, and incident escalation. IDC's research on AI security highlights that data control and identity management are two foundational pillars for securing generative AI adoption, which aligns closely with this SAIF-based control sequence. Once the AI system is live, SAIF continues to guide monitoring, improvement, and periodic reassessment.

## Core building blocks of SAIF

***Expanding strong security foundations to the AI ecosystem:*** The first building block is about extending existing security foundations into AI. Most organisations already have controls for identity, network security, data protection, vulnerability management, application security, and secure software development. SAIF asks enterprises